CyberArkHound

Integrating CyberArk Privileged Access into BloodHound Attack Path Analysis

Julián García Murias
Javier Néstor Azofra Ovejero

whoami

Javier Azofra Ovejero

Head of Continuous Assessment @ Siemens Healthineers

- BSc Telecommunications Engineering.
- MSc Telecommunications and MSc Cybersecurity.
- Identity Security and Attack Path Management.
- Author of CyberArkHound, vCenterHoundGo.
- Co-author of MSSQLHound port to Go.
- Author of ShareHound port to Go.

whoami

Julián García Murias

Blue Team Specialist @ Siemens Healthineers

- Software Engineering Bsc (Oviedo, Asturias, Spain).
- Full Stack Developer in my early career days.
- Advanced Security and Digital Forensics Msc (Edinburgh, Scotland).
- Cyber Security SOC/CSIRT Analyst.
- Purple Team Coordinator in Siemens Healthineers.

Agenda

01 **Why Attackers Hunt PAM**

02 CyberArk implementation in Siemens Healthineers

03 Tradecraft – When PSM Becomes the Path

04 CyberArkHound Development

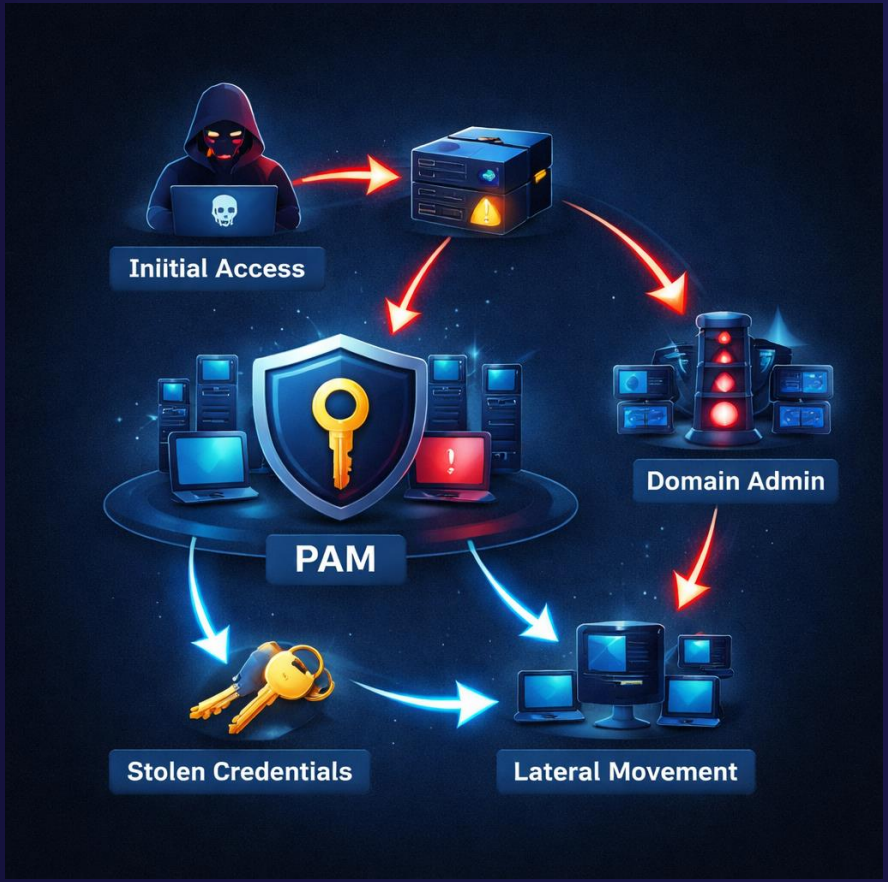
05 Putting CyberArkHound into Practice

Are Attackers Hunting PAM?

Threat Intelligence Reality Check

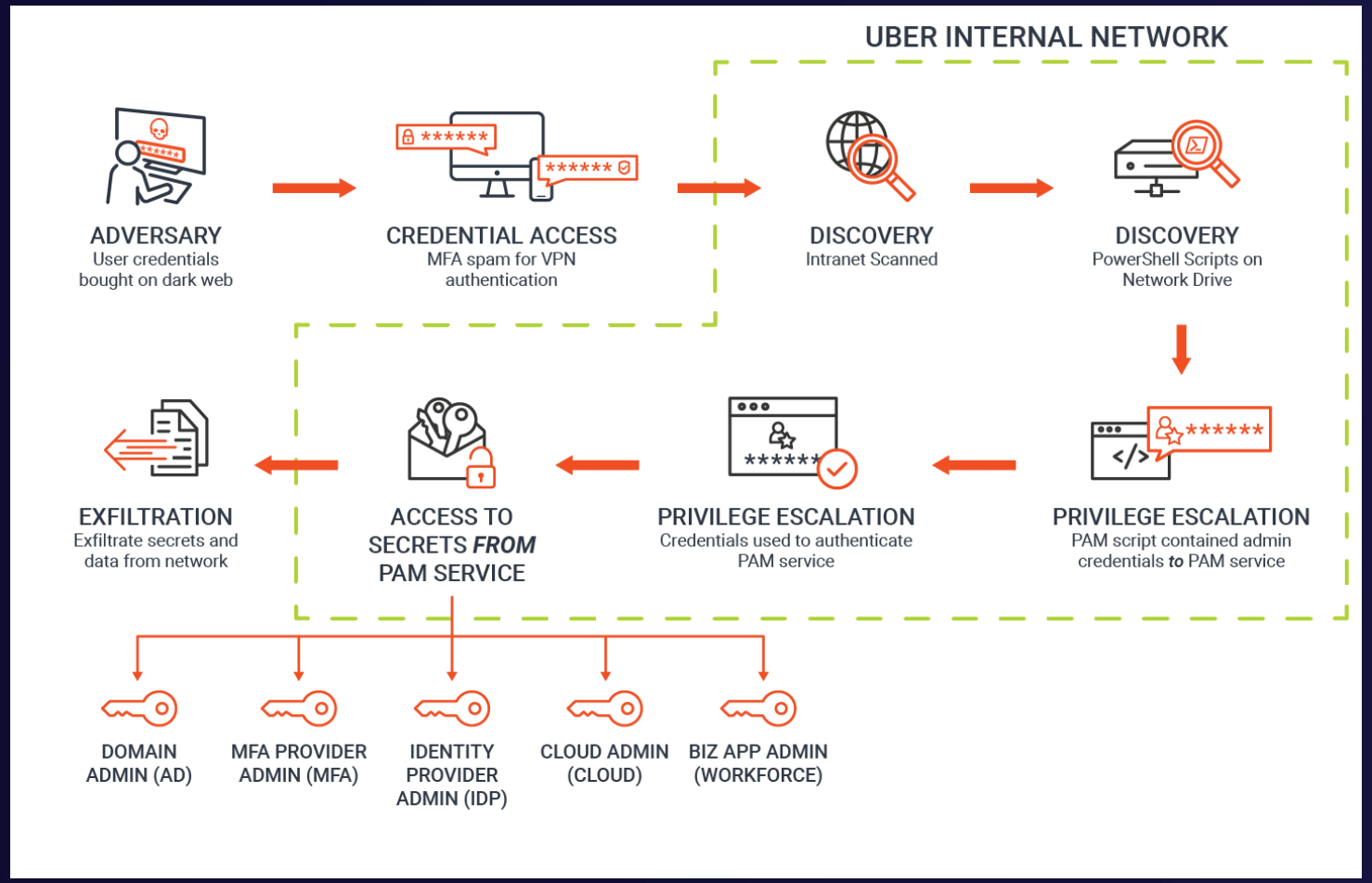
How are PAM solutions being "exploited" in modern cyberattacks?

- What "targeting PAM" looks like in the real world:
  - **Compromise the PAM vendor** / remote support channel.
  - After initial access, **pivot to the *customer's* PAM** to steal/abuse privileged creds and secrets.
  - Exploit **PAM/secret-manager vulnerabilities**.



PAM Under Fire: A Real-World Attack Case

Unpacking the famous CyberArk Uber Breach



The Uber Breach demonstrated that PAM compromise accelerates lateral movement and enables rapid privilege escalation.

- The attackers discovered a PowerShell script with **hard-coded admin CyberArk credentials** on an open SMB network share.
- These **credentials** allowed the attacker to escalate privileges, compromise **SSO** and access sensitive systems such as **cloud management consoles**.

Threat actors after Privileged Credentials

Source	Notable Techniques	Threat Actor
Mandiant analysis of UNC3944 TTPs targeting SaaS	Social Engineering Helpdesk → OAuth Abuse → **PAM Pivot** → Cloud Data Theft	**Scattered Spider** (UNC3944)
Reliaquest Scattered Spider Attack Analysis	Social Engineering on IT Admin → Okta SSO Abuse → Citrix Abuse → **LastPass Pivot** → OnPrem Data Exfiltration	**Scattered Spider** (UNC3944)
Thanksgiving Security Incident	Okta abuse → Session hijacking → **Access to Cloudflare secrets repository** → Credential Harvesting	**Midnight Blizzard (APT 29)**

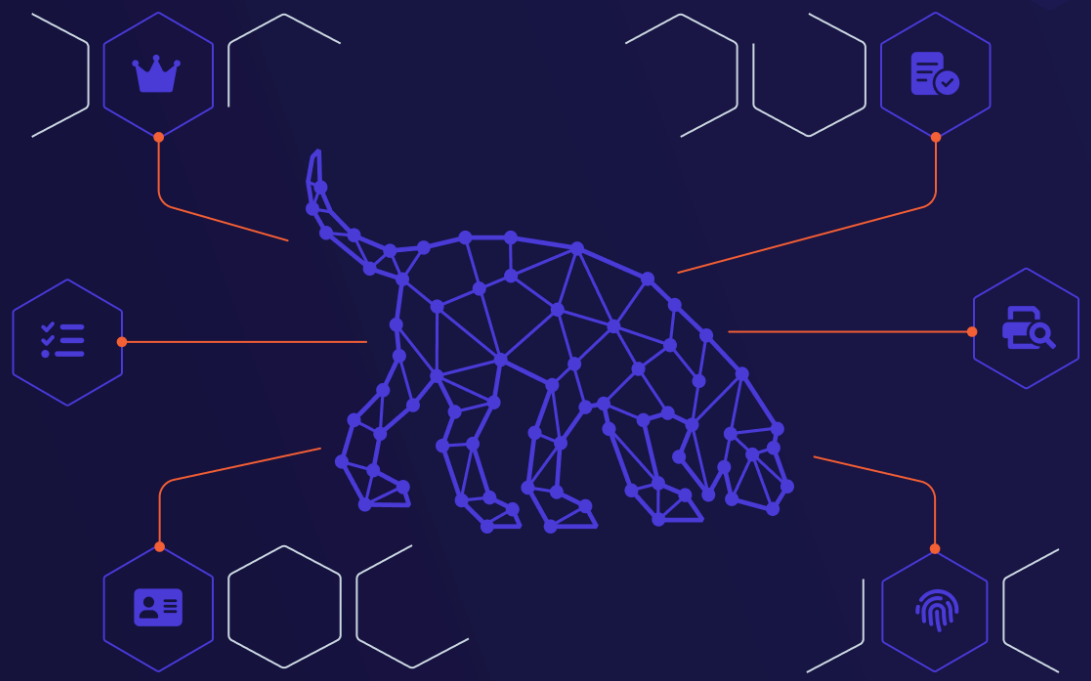
Conclusion: Attackers follow the Credentials

Credential Access as a Core Adversary Objective

None of these attackers brute forced their way to privileged credentials.

- Attacks have leveraged **existing identity relationships**.
- This is why **graph-based attack path analysis** is crucial.
- The defenders who **map these paths before the attackers** are the ones who succeed.

Developing CyberArkHound will likely be worth the effort!



Agenda

01 Why Attackers Hunt PAM

02 **CyberArk implementation in Siemens Healthineers**

03 Tradecraft – When PSM Becomes the Path

04 CyberArkHound Development

05 Putting CyberArkHound into Practice

What is CyberArk PAM?

Enterprise platform for securing, controlling and monitoring privileged access

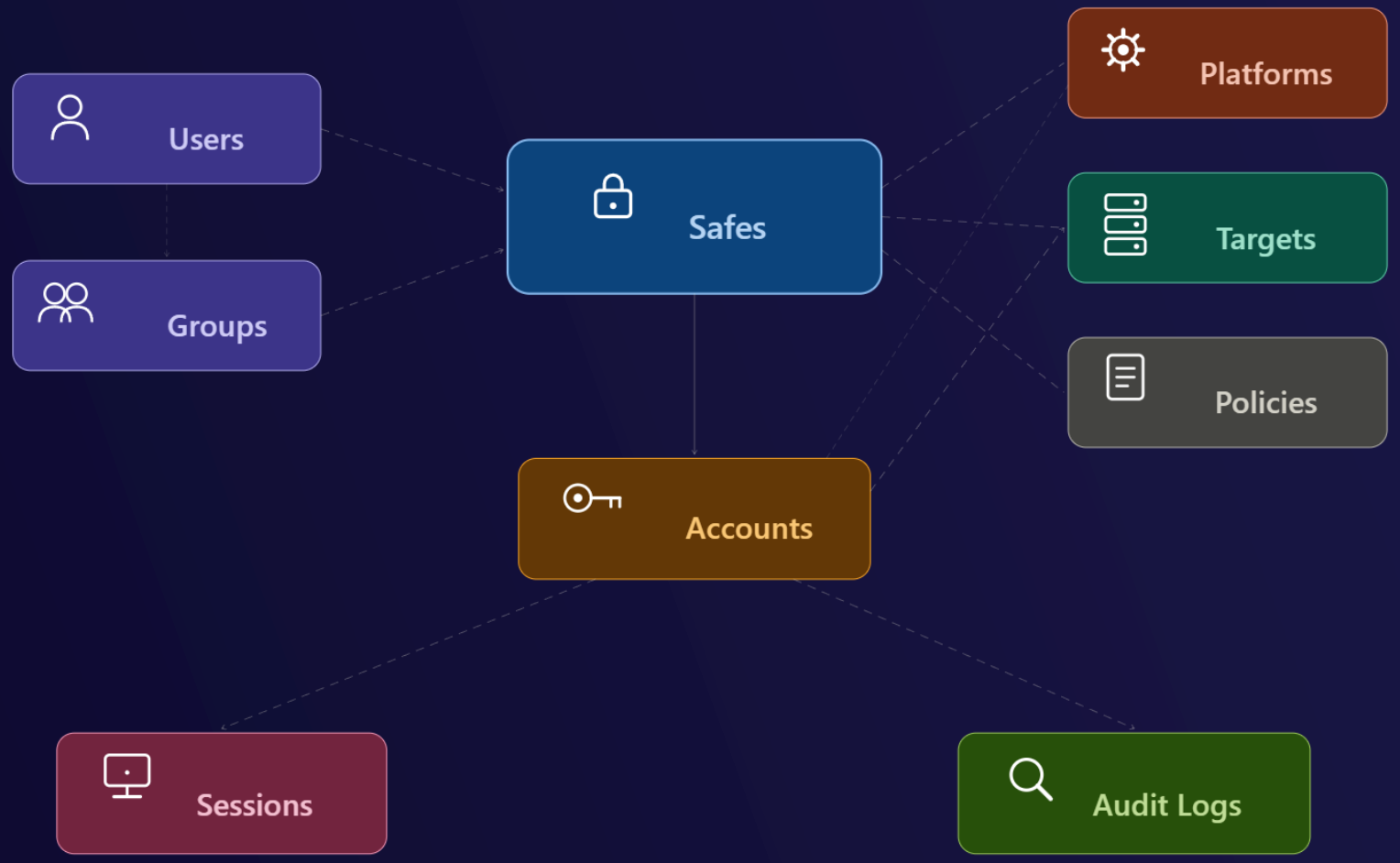
CyberArk is an Enterprise platform for securing, controlling and monitoring privileged access.

- Secure vaulting for privileged credentials.
- Automatic password/secrets rotation.
- Privileged session monitoring and recording (RDP/SSH).
- Secrets management for applications and DevOps.

CyberArk protects the identities attackers care about most.

CyberArk Architecture

How CyberArk secures, manages and monitors privileged access



CyberArk Implementation in Healthineers

CyberArk introduction

Accounts and Safes Provisioning

- Accounts are provisioned from our **Internal Identity & Access Management (IAM) platform**.
- Huge number of **Personalized privileged accounts,** accessible only from his sponsor.
- Shared **admin and local accounts** are onboarded too.

Some statistics:

- **Users:** 6,592
- **Groups:** 4,220
- **Safes:** 15,133
- **Accounts:** 121,594

CyberArk Implementation in Healthineers

CyberArk introduction

CyberArk Instances Setup

- **On Premise**, currently in **migration phase to CyberArk SaaS**.
- Dedicated instance for our **Domain Administrators**.
- SAML authentication, protected with **MFA** and **Conditional Access policies**.
- CyberArk Accounts are provisioned with the **full account UPN**.

Current ongoing work

- Reduction of the **attack surface**.
- Moving towards **shared admin accounts**.
- Evaluation of new models, such as of **zero standing privileges** (access accounts created on the fly).

Privileged Paths in PAM Accounts

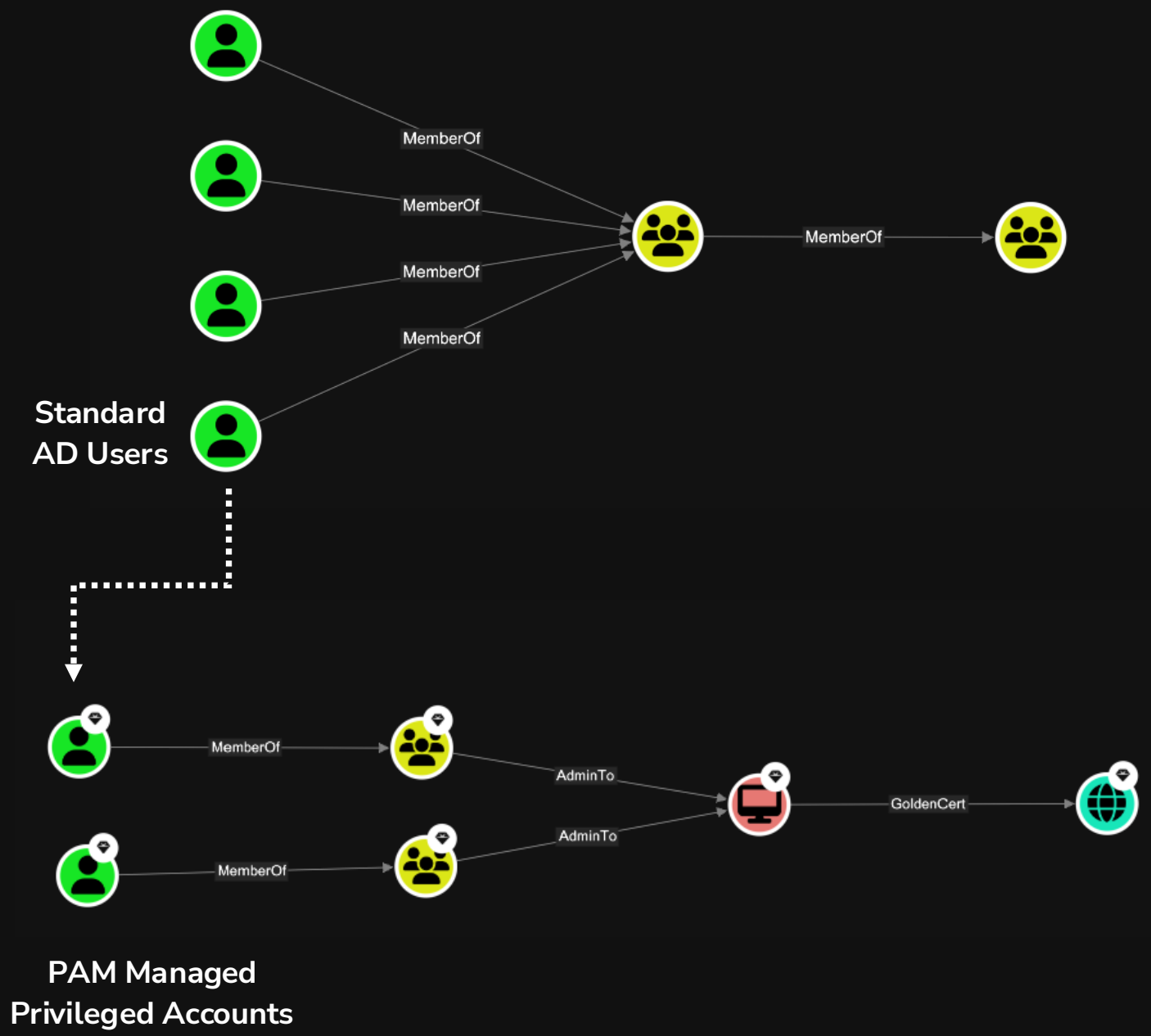
Understanding privileged CyberArk sponsorship relationships

How the relationship via CyberArk sponsorship works:

- A **standard AD/Entra ID user** may be the sponsor of a privileged **PAM-managed account** stored in CyberArk.
- This allows the user to **request and use elevated credentials** when needed.

Since these privileged accounts can be part of Tier Zero:

- Would that user also be part of *Tier Zero*?
- Can we map this within BloodHound?



Agenda

01 Why Attackers Hunt PAM

02 CyberArk implementation in Healthineers

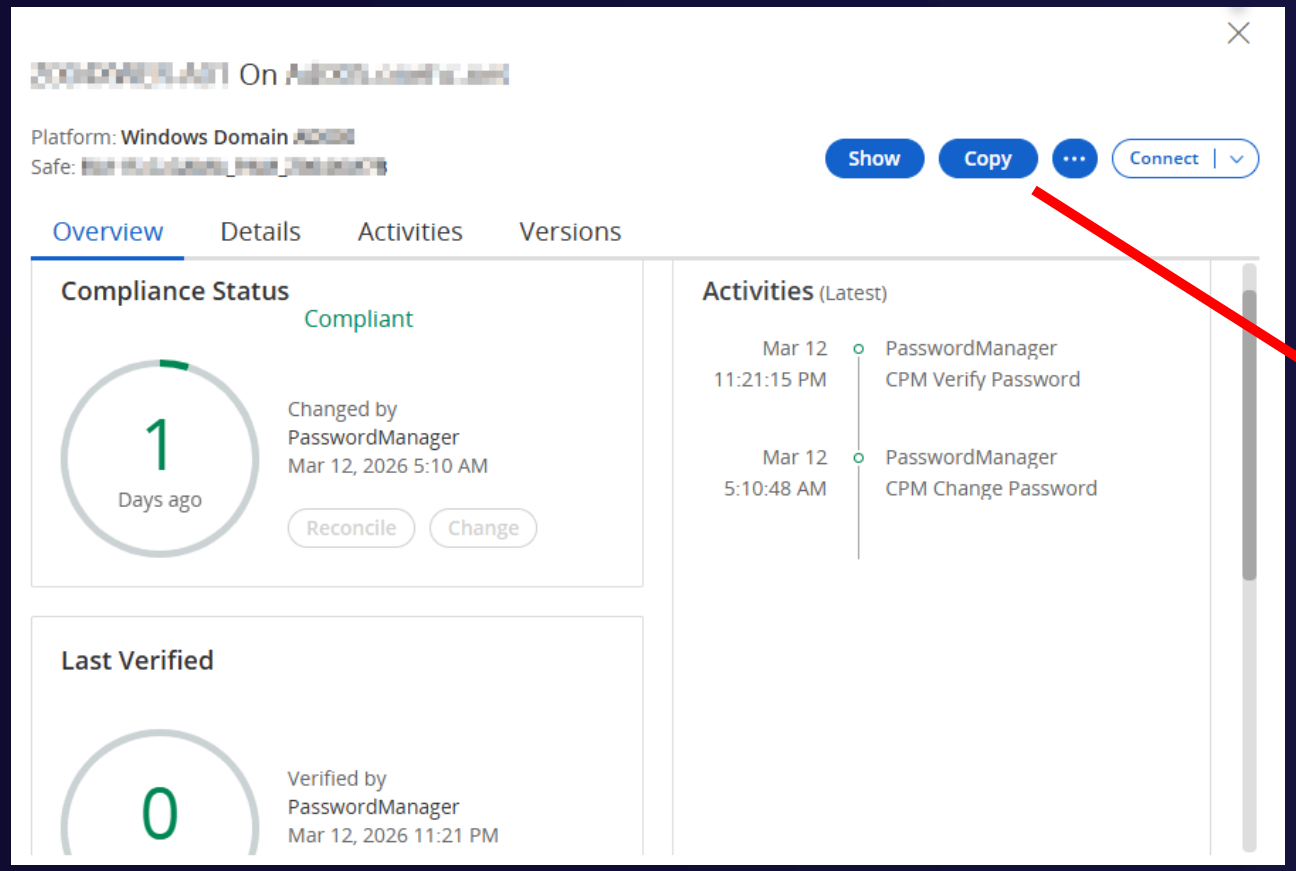
03 **Tradecraft – When PSM Becomes the Path**

04 CyberArkHound Development

05 Putting CyberArkHound into Practice

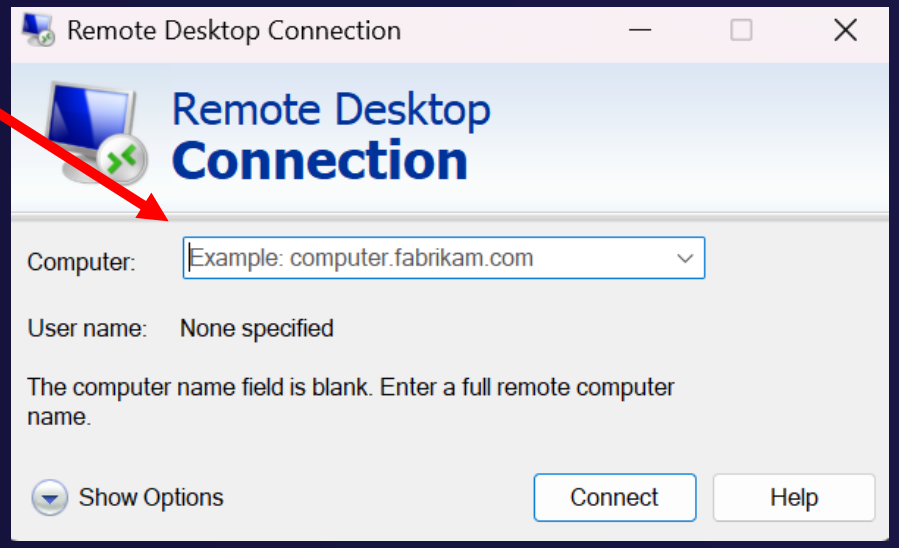
Connecting to a target server using CyberArk

Connect to a target server using privileged CyberArk managed account



CyberArk allows to authenticate against a target server in two different ways:

1. Retrieving the credentials and using them through native Windows RDP.

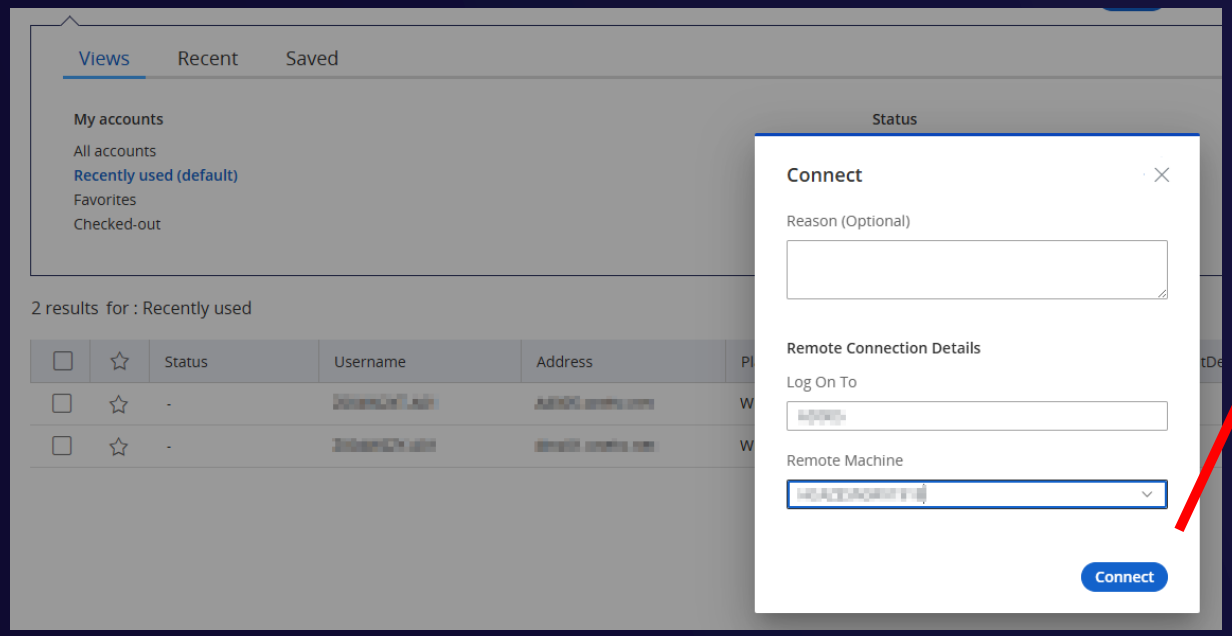


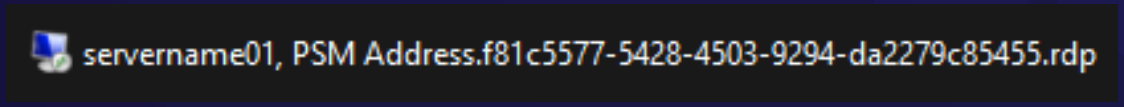
Connecting to a target server using CyberArk

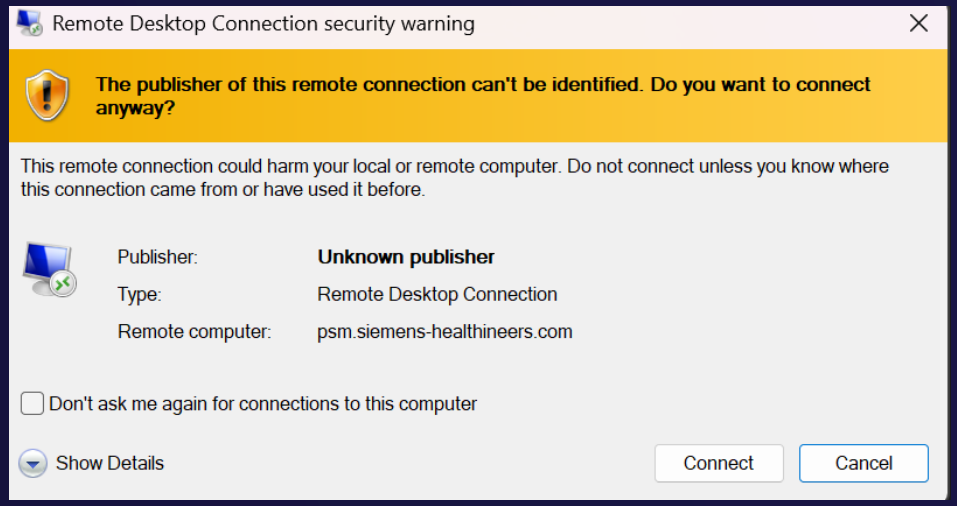
Connect to a target server using privileged CyberArk managed account

CyberArk allows to authenticate against a target server in two different ways:

2. Using CyberArk Privileged Session Manager (PSM).







Opening the Gate: Reusing CyberArk PSM files

Crafting an RDP file to connect through PSM providing the target details

The .rdp file provides the PSM with all the details so a successful connection can be done to a target server.

- The PSM **full address** parameter allows to connect to a specific CyberArk PSM.
- The **alternate shell** parameter is used to ask the session to launch PSM connection component instead of the default Windows shell *(explorer.exe)*.
- Additional parameters, such as **injected credentials** or a **target server** can be added to **alternate shell** so they can be read by the PSM.

```
full address:s:[redacted]
server port:i:3389
username:s:PSM@6faa46b0-fd1f-4fa8-810d-fe98c30700e7
alternate shell:s:PSM@6faa46b0-fd1f-4fa8-810d-fe98c30700e7
desktopwidth:i:1024
desktopheight:i:768
screen mode id:i:2
redirectdrives:i:0
drivestoredirect:s:
redirectsmartcards:i:0
EnableCredSspSupport:i:0
redirectcomports:i:0
remoteapplicationmode:i:0
use multimon:i:0
span monitors:i:0
smart sizing:i:1
authentication level:i:2
```

servername01, PSM Address.f81c5577-5428-4503-9294-da2279c85455.rdp

Can we modify the downloaded .rdp file to connect using the PSM and bypass MFA and Conditional Access?

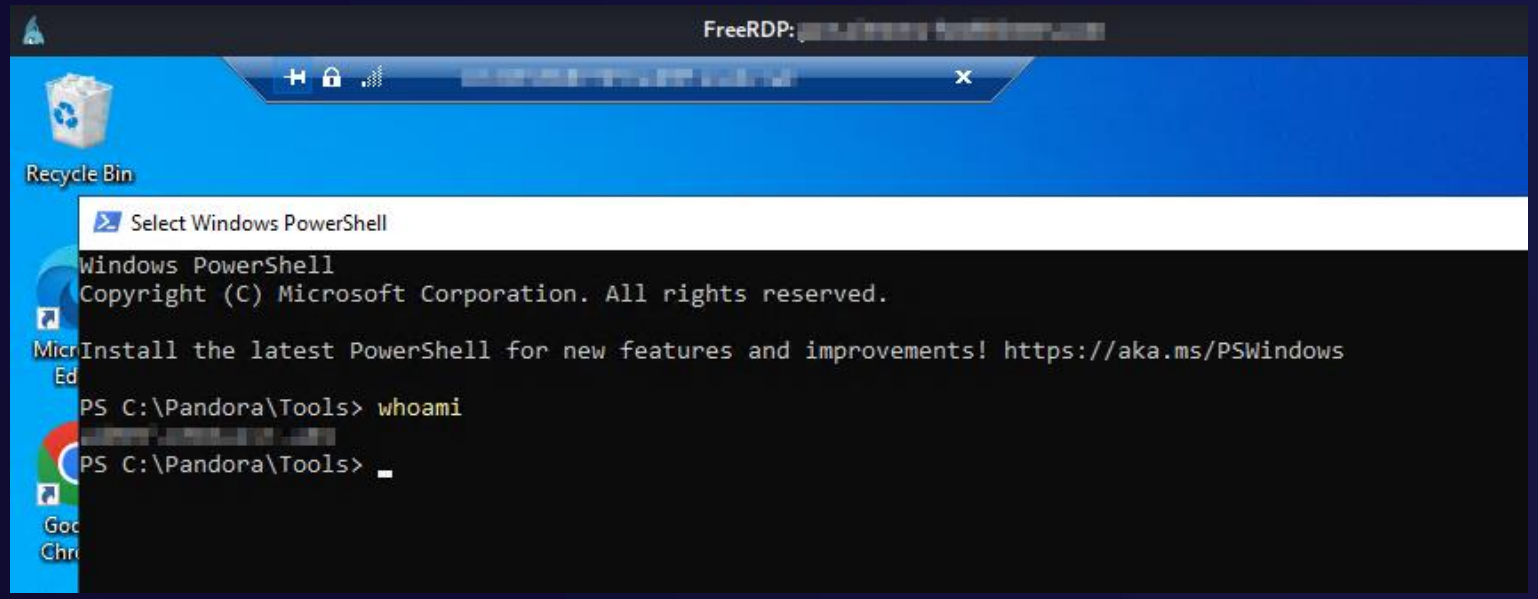
Reusing CyberArk PSM files : Bypassing SAML

Crafting an RDP file to connect through PSM providing the target details

Login is successful when using AD corporate credentials.

```
full address:s:psm.domain.com
alternate shell:s:psm /u PRIVUSER@domain.com /a TARGET_SERVER.domain.com /c psm-rdp
username:s:STDUSER
```

```
┌──(root㉿[redacted])-[/home/kali]
└─# xfreerdp test.CUSTOM_PSM.rdp /p:PASSWORD /u:fulluserupn@domain.com
```

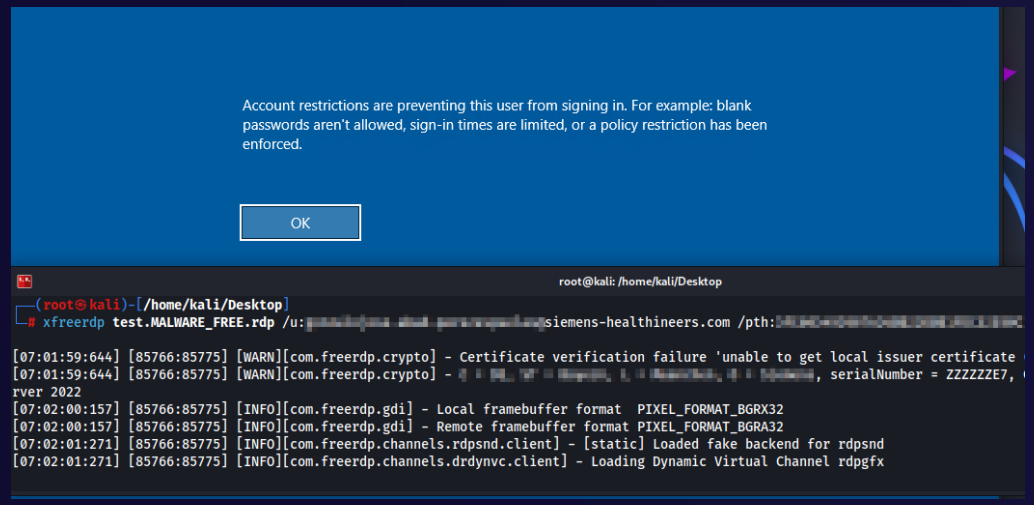


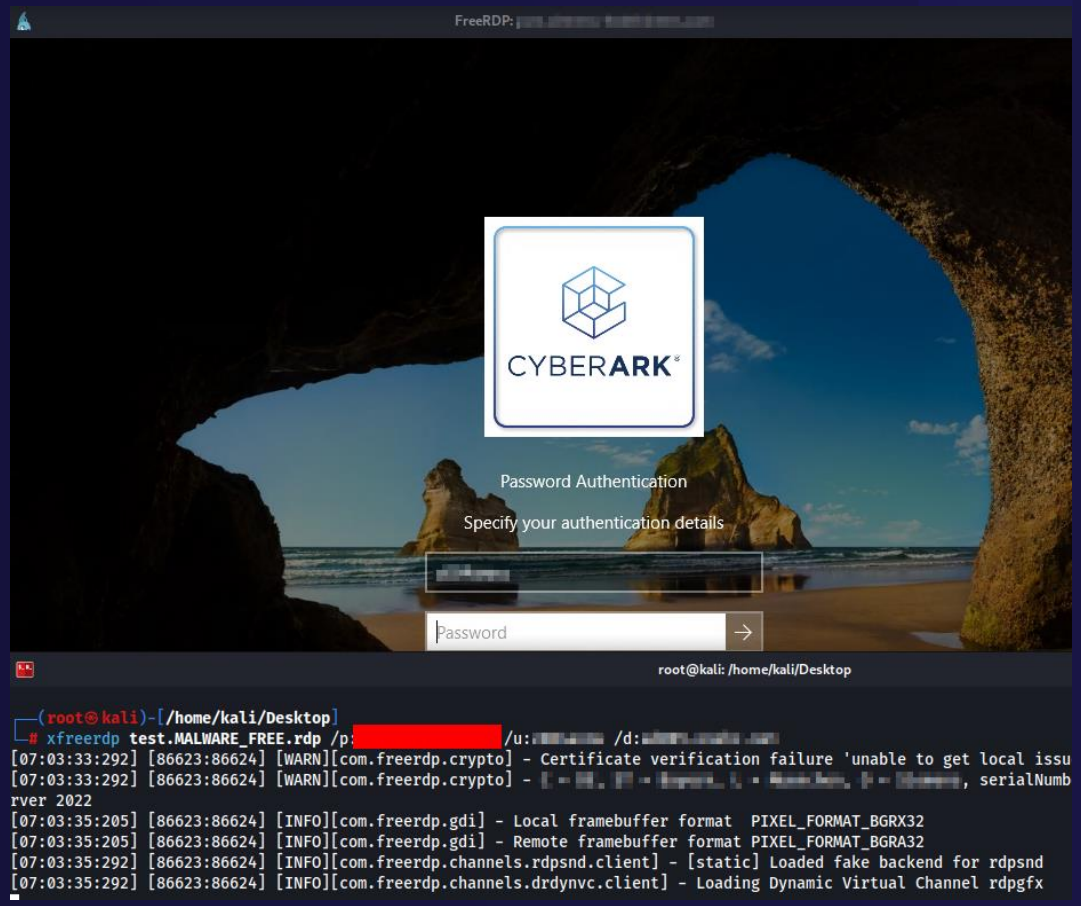
Reusing CyberArk PSM files : Bypassing SAML

Crafting an RDP file to connect through PSM without providing the target details

Authentication attempts using the SamAccountName directly or via Pass-the-Hash both fail.

- **Pass-The-Hash:** PSM does not allow PtH-style logons.
- **SamAccountName:** The first RDP connection to the PSM server is allowed, but when the system attempts to retrieve the privileged credentials from the CyberArk vault, it prompts for authentication.





SAML Bypass – “Attack” pre-requirements Summary

Account Ownership via PAM

- The victim must have permissions to retrieve the password of the privileged account via PAM.

RDP access to Target Server

- The privileged account must be in a group that grants Remote Desktop logon rights on the target system.
- RDP needs to be enabled on the target system, and port 3389 needs to be reachable from the PSM server.

AD Account Compromise

- The authentication must be done using AD/Entra ID credentials.
- The full UPN and the AD standard account need to be known.
- AD user clear text password needs to be available.

PSM Transparent Access: A Feature by Design

Risk acknowledged, mitigation in progress via SAML enforcement

This feature has been designed to improve usability and enable native client RDP access.

- Mitigation strategy in progress:
  - Enforcing **SAML Auth** in **PSM transparent connections**.
  - Connections using custom PSMs will not work without satisfying **MFA** and **Conditional Access**.

Agenda

01 Why Attackers Hunt PAM

02 CyberArk implementation

03 Tradecraft – When PSM Becomes the Path

04 **CyberArkHound Development**

05 Putting CyberArkHound into Practice

The Visibility Gap

CyberArk: The Crown Jewels Vault

- CyberArk PAM manages the most sensitive credentials: Domain Admin passwords, service accounts, root keys.
- The internal relationships between users, groups, safes, and accounts are completely invisible to attack path tools.
- BloodHound maps AD attack paths end-to-end but stops at the vault door.

This had been unanswerable. Until now.

What Attackers Already Know

- Red teams don't stop at AD boundaries. Once they compromise a CyberArk user, they explore:
  - **Group memberships** granting safe management
  - **Safe permissions** for credential retrieval
  - **Dual-control bypasses** circumventing approval
  - **Credential chains** cascading through linked accounts
- Defenders need the same visibility at graph scale.

What is CyberArkHound?

The Tool

- Open-source Go tool that exports CyberArk PVWA vault structure into BloodHound-compatible OpenGraph JSON format.
- Maps 5 node types and 14 edge types covering privilege escalation, credential access, dual-control approval, and audit trails.
- 100% read-only. 50-200 concurrent workers.

Why It Matters

- CyberArkHound answers who can access what credentials, who can escalate privileges via safe management, and who actually used credentials recently.
- Sync edges bridge CyberArk to AD.
- Imports into BloodHound CE or Enterprise.

CyberArk Graph Model: Node Types

Identity Nodes

- **CyberArkUser** - Vault users with authorization levels, LDAP sync status, and distinguished names for AD correlation.
- **CyberArkGroup** - Groups with membership hierarchies, directory mapping, and safe permission inheritance.

Vault Nodes

- **CyberArkSafe** - Credential containers with creator, CPM assignment, retention policies, and member access control lists.
- **CyberArkAccount** - Managed credentials with platform, target address, requiresApproval flag, and management status tracking.

Configuration Nodes

- **CyberArkPlatform** - Master Policy definitions for dual-control, password rotation, and shared attack surface grouping.
- All nodes namespaced with a 4-char PVWA tag to prevent cross-instance collisions in multi-vault environments.

Core Edge Types: Access and Escalation

Access Edges

- **CyberArkHasAccessTo** - Direct credential access via useAccounts or retrieveAccounts permissions. Carries requiresApproval flag.
- **CyberArkCanGrantAccessTo** - Privilege escalation: manageSafe or manageSafeMembers lets members self-grant retrieval access.
- **CyberArkCanApprove** - Dual-control approval authority via requestsAuthorizationLevel1/Level2.

Structural Edges

- **CyberArkMemberOf** - Group membership hierarchy enabling permission inheritance.
- **CyberArkContains** - Safe-to-account containment relationship.
- **CyberArkCreated / CyberArkManagedBy** - Safe ownership and CPM management assignment.

Audit Edges and External Sync

External Sync Edges

- **SyncsToCyberArkUser** (User to CyberArkUser) - Maps AD users to their CyberArk vault.
- **SyncsToCyberArkGroup** (Group to CyberArkGroup)- Maps AD groups to their synced CyberArk group counterparts
- **SyncsToADUser** (CyberArkAccount to User)- Links CyberArk managed accounts to the AD users they represent, using target address domain matching against --target-domains configuration.
- **CyberArkCanConnect** (CyberArkAccount to Computer) - Create CyberArkCanConnect edge from CyberArkAccount to AD Computer if address is a subdomain of the target domain

The Bridge Effect

- These sync edges are what make CyberArkHound transformative: they connect CyberArk's internal permission graph directly to BloodHound's AD attack paths, enabling end-to-end analysis from domain user to Domain Controller through the vault.

Audit and Dependency Edges

- **CyberArkUsedAccount** (User to Account)
- **CyberArkLinkedTo** (Account to Account).
- **CyberArkUsesPlatform** (Account to Platform)

Enabled via --include-activity, --include-linked-accounts, and --include-platforms flags respectively.

Dual-Control Enforcement: 3-Layer Model

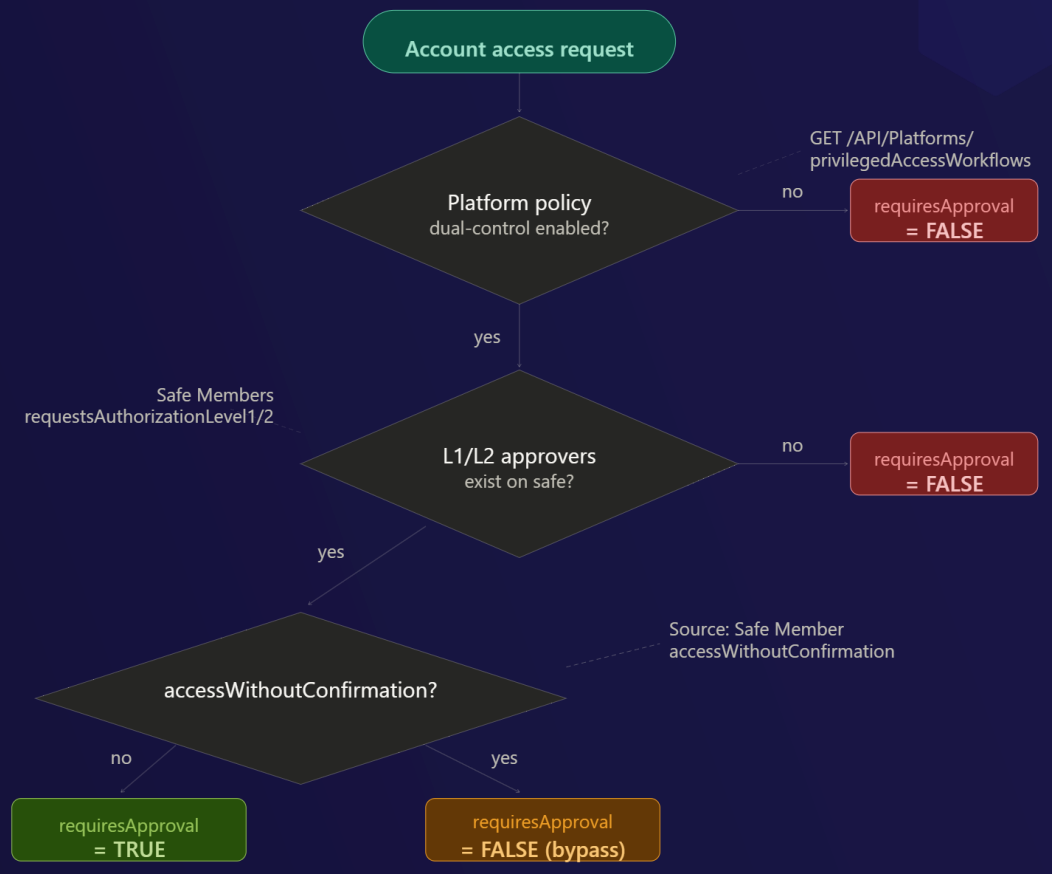
Challenging problem to audit at scale that CyberArkHound solves

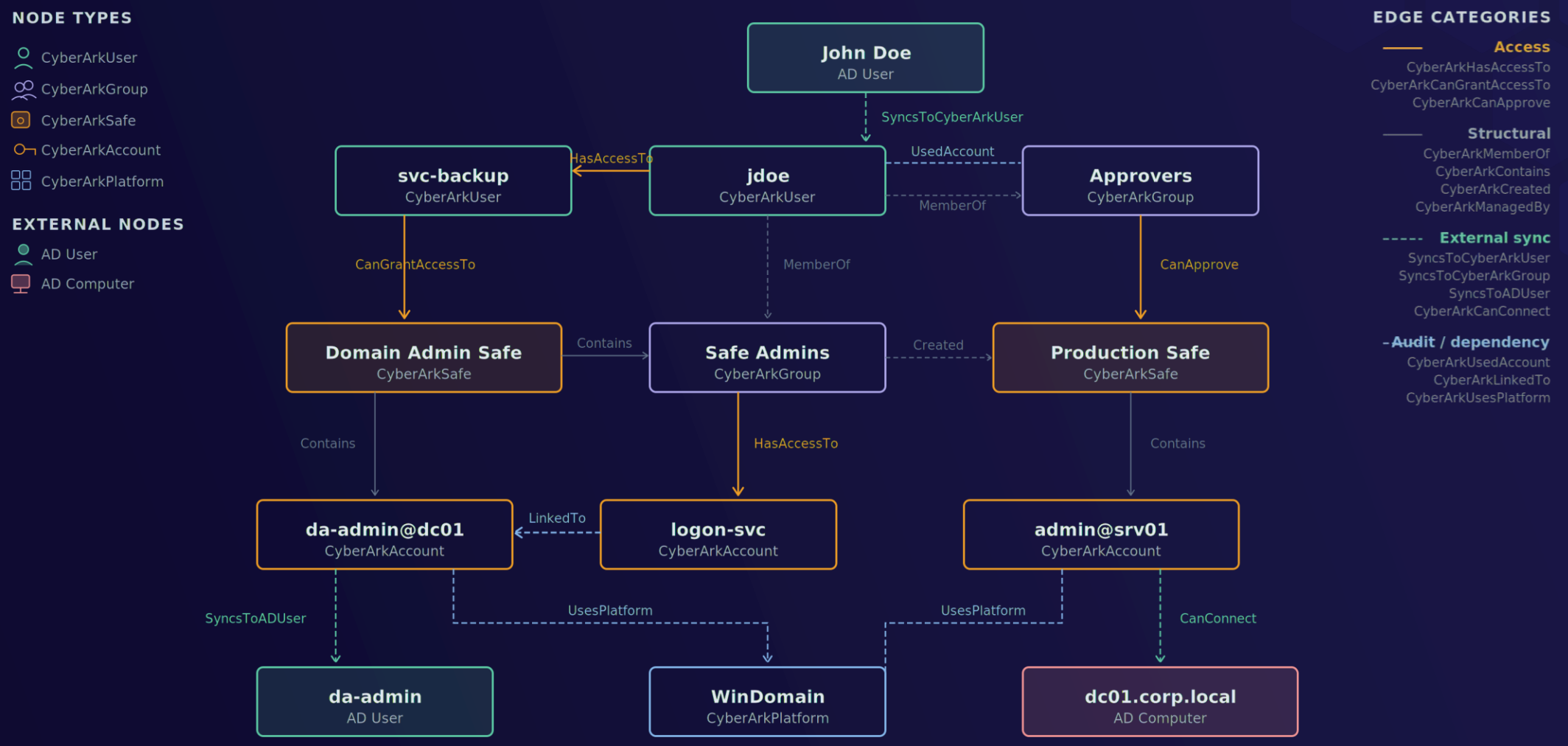
- **Layer 1 - Platform Policy:** Master Policy must enable requireDualControlPasswordAccessApproval.
- **Layer 2 - Approver Presence:** At least one L1/L2 approver must exist on the safe.
- **Layer 3 - Member Bypass:** accessWithoutConfirmation = true overrides all approval requirements.
- *Result: requiresApproval = true only when policy enabled AND approvers exist AND no bypass.*

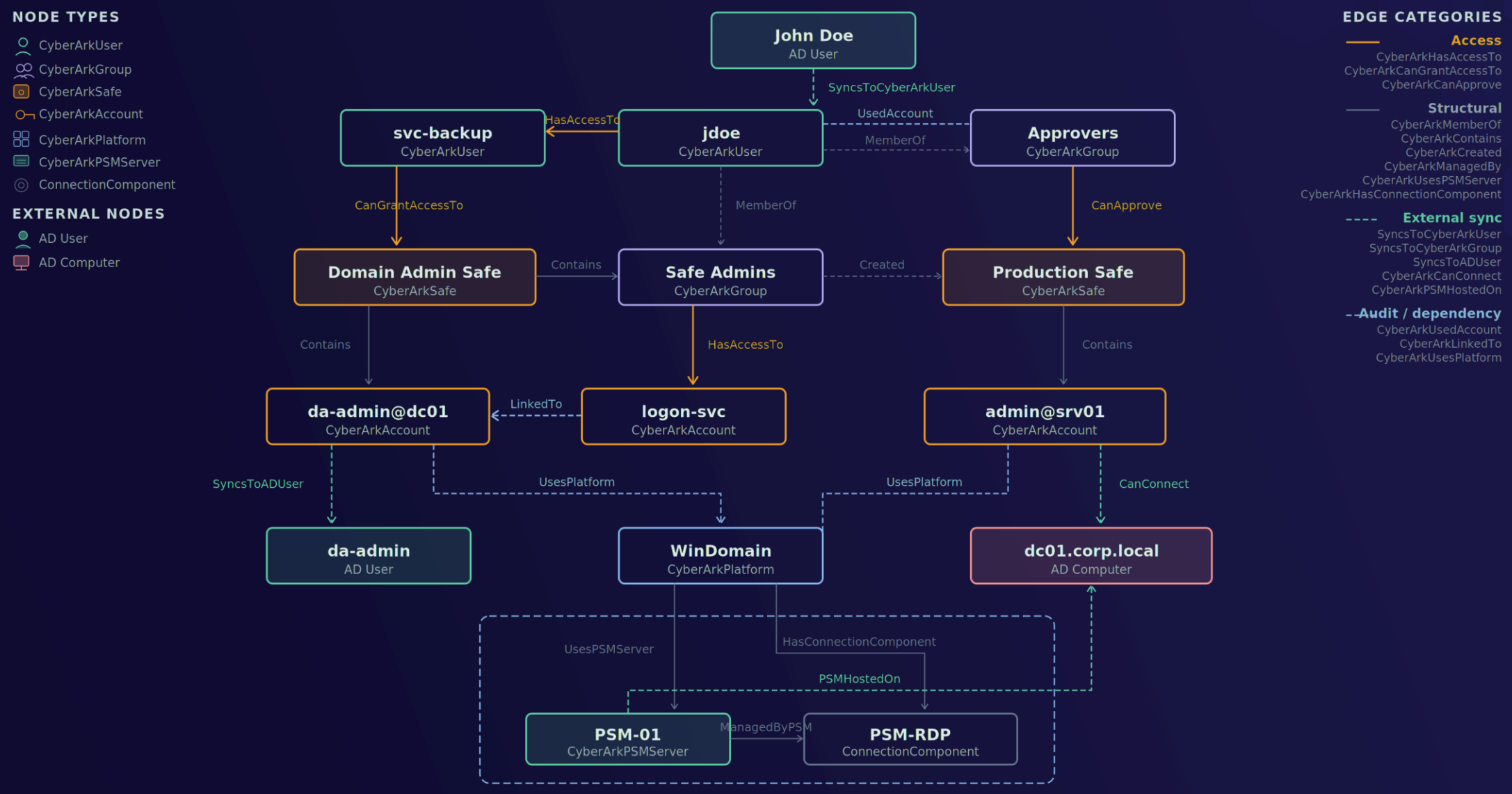
Cypher Query:

```
MATCH p=(u:CyberArkUser)-[r:CyberArkHasAccessTo {requiresApproval: true}]->(a:CyberArkAccount)

RETURN p
```




NODE TYPES
CyberArkUser
CyberArkGroup
CyberArkSafe
CyberArkAccount
CyberArkPlatform
EXTERNAL NODES
AD User
AD Computer
John Doe
AD User
SyncsToCyberArkUser
svc-backup
CyberArkUser
HasAccessTo
jdoe
CyberArkUser
UsedAccount
MemberOf
Approvers
CyberArkGroup
CanGrantAccessTo
MemberOf
CanApprove
Domain Admin Safe
CyberArkSafe
Contains
Safe Admins
CyberArkGroup
Created
Production Safe
CyberArkSafe
Contains
HasAccessTo
Contains
da-admin@dc01
CyberArkAccount
LinkedTo
logon-svc
CyberArkAccount
admin@srv01
CyberArkAccount
SyncsToADUser
UsesPlatform
UsesPlatform
CanConnect
da-admin
AD User
WinDomain
CyberArkPlatform
dc01.corp.local
AD Computer
EDGE CATEGORIES
Access
CyberArkHasAccessTo
CyberArkCanGrantAccessTo
CyberArkCanApprove
Structural
CyberArkMemberOf
CyberArkContains
CyberArkCreated
CyberArkManagedBy
External sync
SyncsToCyberArkUser
SyncsToCyberArkGroup
SyncsToADUser
CyberArkCanConnect
Audit / dependency
CyberArkUsedAccount
CyberArkLinkedTo
CyberArkUsesPlatform


NODE TYPES
CyberArkUser
CyberArkGroup
CyberArkSafe
CyberArkAccount
CyberArkPlatform
CyberArkPSMServer
ConnectionComponent
EXTERNAL NODES
AD User
AD Computer
John Doe
AD User
SyncsToCyberArkUser
svc-backup
CyberArkUser
HasAccessTo
jdoe
CyberArkUser
UsedAccount
MemberOf
Approvers
CyberArkGroup
CanGrantAccessTo
MemberOf
CanApprove
Domain Admin Safe
CyberArkSafe
Contains
Safe Admins
CyberArkGroup
Created
Production Safe
CyberArkSafe
Contains
HasAccessTo
Contains
da-admin@dc01
CyberArkAccount
LinkedTo
logon-svc
CyberArkAccount
admin@srv01
CyberArkAccount
SyncsToADUser
UsesPlatform
UsesPlatform
CanConnect
da-admin
AD User
WinDomain
CyberArkPlatform
dc01.corp.local
AD Computer
UsesPSMServer
HasConnectionComponent
PSMHostedOn
PSM-01
CyberArkPSMServer
ManagedByPSM
PSM-RDP
ConnectionComponent
EDGE CATEGORIES
Access
CyberArkHasAccessTo
CyberArkCanGrantAccessTo
CyberArkCanApprove
Structural
CyberArkMemberOf
CyberArkContains
CyberArkCreated
CyberArkManagedBy
CyberArkUsesPSMServer
CyberArkHasConnectionComponent
External sync
SyncsToCyberArkUser
SyncsToCyberArkGroup
SyncsToADUser
CyberArkCanConnect
CyberArkPSMHostedOn
Audit / dependency
CyberArkUsedAccount
CyberArkLinkedTo
CyberArkUsesPlatform

Agenda

01 Why Attackers Hunt PAM

02 CyberArk implementation

03 Tradecraft - Crafting a malicious CyberArk PSM

04 CyberArkHound Development

05 **Putting CyberArkHound into Practice**

Putting CyberArkHound into Practice

From Collection to Continuous Threat Exposure Management

1. **Password Vault Web Access (PVWA) API Integration**
   Certificate based authentication to retrieve CyberArk auditor user credentials on the fly via CCP.

2. **Scheduled DevOps Collection Pipelines**
   Daily collection of PVWA instances and automatic file ingest uploads to BHE using BH Operator.

3. **Cypher Queries Development**
   Cypher Queries are created to analyze the relationships between AD and CyberArk nodes.

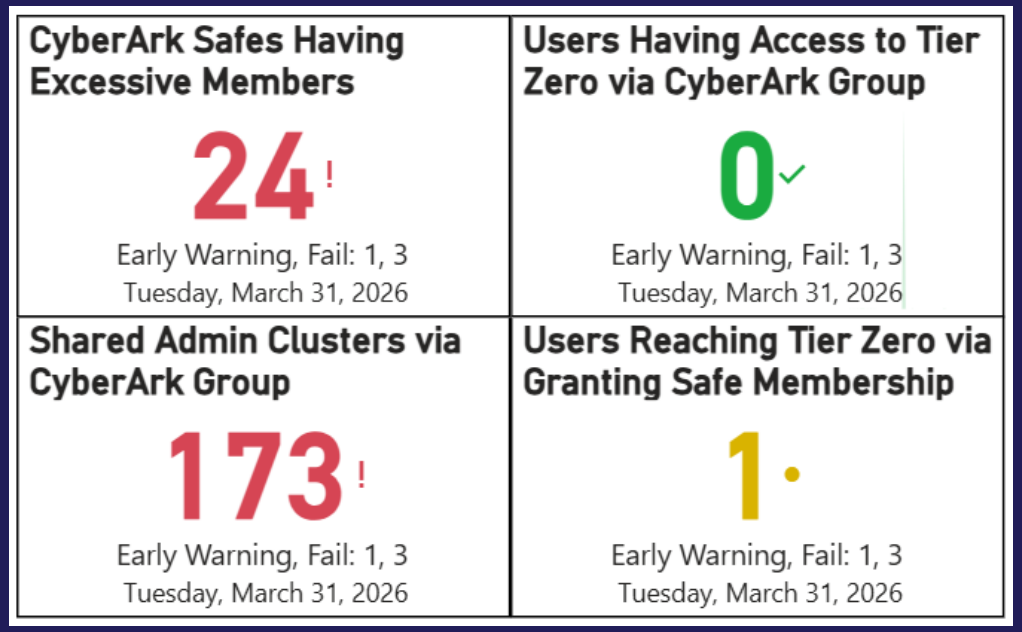
4. **Power BI Exposure Indicators definition and initial cleanup**
   Exposure indicators are created and initial cleanup is performed.

5. **Integration into our Continuous Remediation Process**
   The new generated edges generate automatically an alert in Planner and the alert is reviewed.

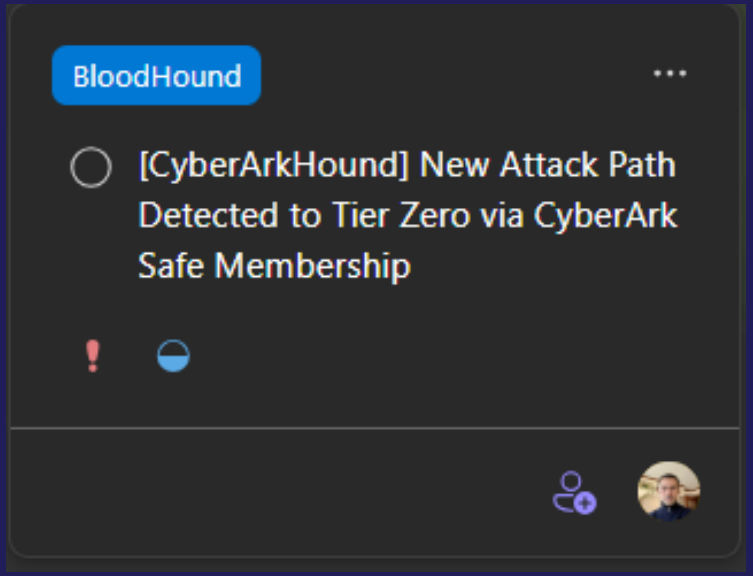
PowerBI Dashboard and Planner Alerts

From Collection to Continuous Threat Exposure Management

Power BI Dashboard – AVM Board



Planner Channel Alerts



CyberArkHound into Practice

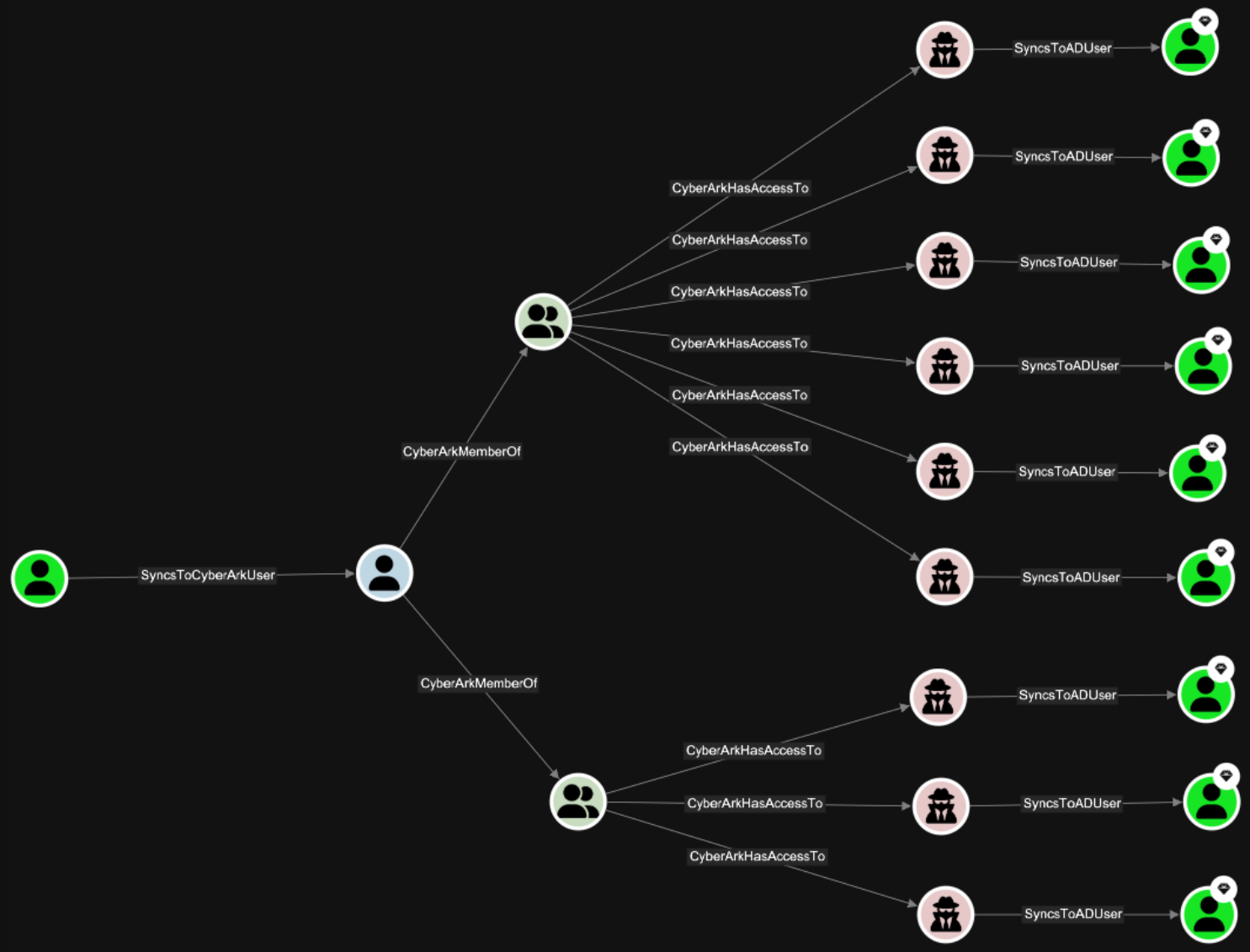
A new visibility layer into PAM Threat Exposure Management

1. Regular Users having access to Tier Zero without Dual Control.

- Regular Users who have access to Tier Zero through CyberArk Group membership.
- **Real Case:** *Global Administrator* being able to retrieve his admin credentials without dual control.

Cypher Query:

MATCH p=(u3:User)-[]->(u2:CyberArkUser)-[]->(v:CyberArkGroup)-[:CyberArkHasAccessTo {requiresApproval: true}]-> (a:CyberArkAccount)-[:SyncsToADUser]-> (u:Tag_Tier_Zero) RETURN p



CyberArkHound into Practice (II)

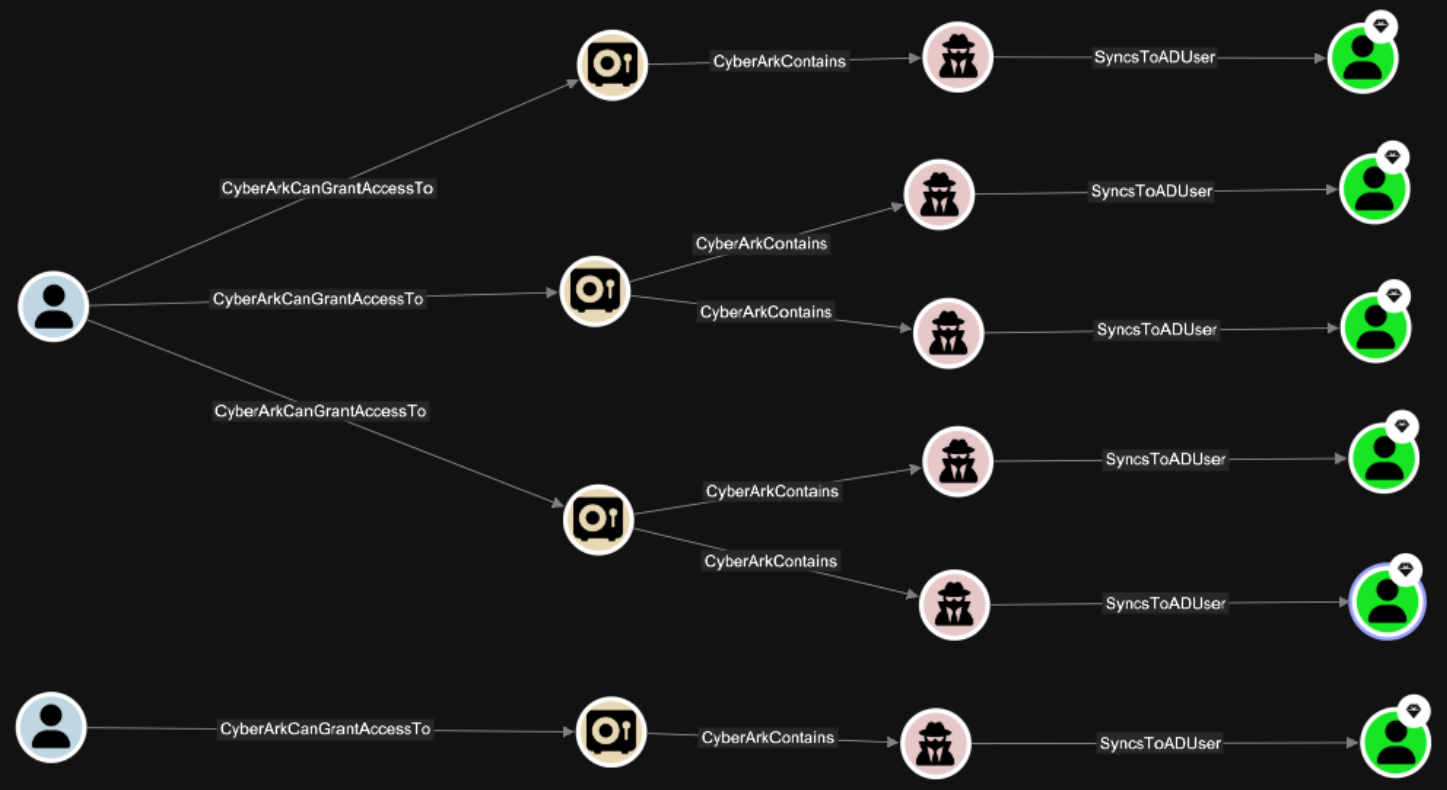
A new visibility layer into PAM Threat Exposure Management

2. CyberArk Users having access to Tier Zero by granting themselves access to a Safe.

- These users could be Local CyberArk users or be AD Synced too.
- **Real Case:** *CyberArk administrator* being able to grant himself access to a safe which contains Tier Zero accounts.

Cypher Query:

```
MATCH p=(v:CyberArkUser)-[:CyberArkCanGrantAccessTo]->(s:CyberArkSafe)-[:CyberArkContains]->(a:CyberArkAccount)-[:SyncsToADUser]->(u:Tag_Tier_Zero)
RETURN p
```



CyberArkHound into Practice (III)

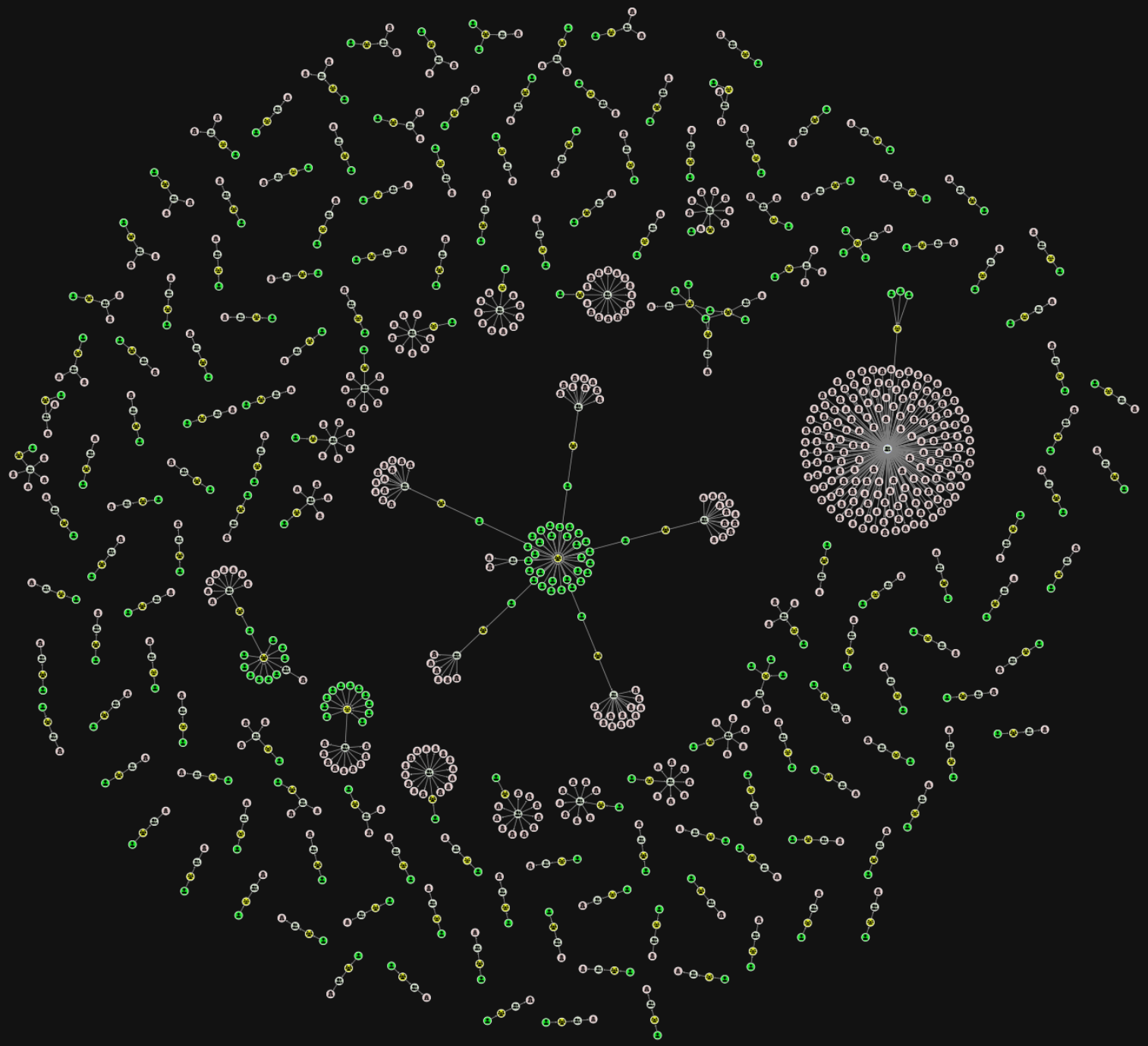
A new visibility layer into PAM Threat Exposure Management

3. Big clusters of Shared Admins being members of the same CyberArk group or Safe.

- CyberArk safes or groups having excessive members.
- **Real Case:** Misuse of PAM as Shared Vault, onboarding multiple accounts with different purposes.

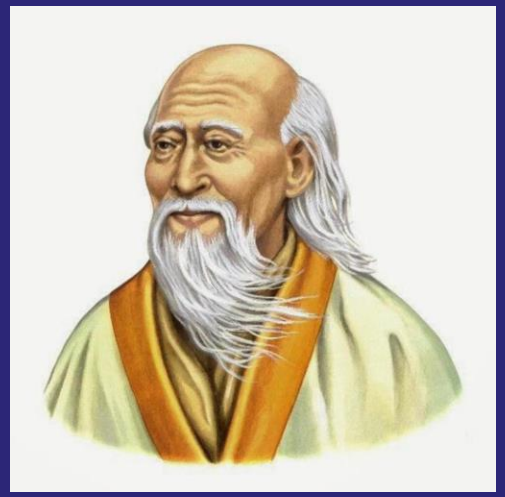
Cypher Query:

```
MATCH  p=(u:User)-[:MemberOf]->(g:Group)-
[:SyncsToCyberArkGroup]->(c:CyberArkGroup)-
[:CyberArkHasAccessTo]->(a:CyberArkAccount)
RETURN p LIMIT 3000
```



“Solve the small problems before they become big”

– **Laozi (Philosopher).**



“What gets measured, gets done.”

– **William Edwards Deming (business theorist, economist, statistician).**

Thank you for attending!

Enjoyed the session?

CyberArkHound: Integrating CyberArk Privileged Access into BloodHound Attack Path Analysis

SPECTEROPS SO·CON 2026

Scan me to leave your feedback ☺